



АКАДЕМИЯ
КОДЕБАЙ

ПРОФЕССИЯ ПЕНТЕСТЕР

P.S. Burp Intruder, поставляемый в комплекте с Burp Suite Community Edition, имеет статус Демо-версии и делает задержку на 1 секунду между запросами.

Burp Intruder

Burp Intruder — это один из ключевых компонентов пакета инструментов для тестирования безопасности веб-приложений Burp Suite. Intruder предназначен для автоматического и полуавтоматического поиска уязвимостей в веб-приложениях путем модификации и повторной отправки HTTP-запросов.

Burp Intruder предлагает четыре различных режима атаки, которые позволяют адаптировать тестирование под определенные сценарии:

Sniper - при этом виде атак используется отдельный набор опасных данных. Burp Intruder начинает по очереди брать все обозначенные маркерами позиции в запросе и помещать отдельно в каждую специально сформированные данные. Остальные позиции не обрабатываются - их маркеры удаляются из тела запроса, а содержимое остаётся нетронутым. Данный тип атак полезен при индивидуальном тестировании полей на наличие общих уязвимостей (таких как XSS). Итоговое количество отправляемых запросов здесь может быть посчитано путём умножения количества позиций для опасных данных на количество вариантов этих данных в используемом наборе.

Battering ram - здесь используется отдельный набор опасных данных. Перебирая записи в нём, Burp Intruder помещает проверочный текст сразу во все позиции, отмеченные маркерами. Это может пригодиться, когда для осуществления атаки необходимо помещать одни и те же данные сразу во множество мест. Например, имя пользователя в Cookie и в тело запроса. Итоговое количество запросов равняется количеству записей в наборе проверочных данных.

Pitchfork - этот вид атак использует несколько наборов проверочных данных. Таким образом для каждого отрезка, обозначенного маркерами (максимум 8), устанавливаются свои специально сформированные строки. Burp Intruder перебирает наборы тестовых строк одновременно и помещает данные из них в каждый обозначенный участок запроса. Например, при первом запросе первая строка из первого проверочного набора будет

помещена на первое место, обозначенное маркерами. А первая строка из второго набора поместится на вторую позицию. При формировании второго запроса на первое место будет помещена вторая строка из первого набора, а на второе - вторая строка из второго набора. И так далее. Такой вид атак может пригодиться в ситуациях, когда приложению нужно отсылать всё время разные, но каким-то образом взаимосвязанные данные. Например, если необходимо отправлять имя пользователя в одном поле и его ID в другом. Общее количество запросов, совершаемых при проведении атак такого рода, измеряется количеством строк в наименьшем используемом проверочном наборе.

Cluster bomb - данный вид атак использует несколько проверочных наборов. Для каждого отрезка, обозначенного маркерами (максимум 8), устанавливаются свои специально сформированные строки. При проведении атаки Burp Intruder проверяет все возможные комбинации выражений из всех тестовых наборов. То есть если у вас есть 2 проверочных набора, то при первом запросе Intruder поместит на первую позицию первую строку из первого набора, на вторую первую строку из второго. При втором запросе на первом месте останется первая строка первого набора, а на вторую будет помещена вторая строка второго набора. Потом третья, и так далее. Данный вид атак может быть полезен в ситуациях, когда требуется помещать в запрос разные, никак не связанные между собой данные. Например, имя пользователя в один параметр и неизвестный пароль в другой. Общее количество запросов, генерируемых при реализации данной атаки, может быть большим, не забывайте об этом.

Команды, используемые в уроке:

```
kali@kali:~$ dirb http://192.168.0.174 -r
```